

Aether AI 风险与模型治理标准

受控发布版本 | 所有者：AI 治理委员会 | 生效日期：2026-08-01 | 分类：内部限制

控制项	要求
批准角色	AI 治理委员会、信息安全负责人、数据保护官
适用范围	面向客户的 Agent、检索、模型配置与自动化工作流
复审触发	模型替换、高风险场景上线、重大安全事件或季度评测复核

1. 目的与治理原则

1.1 可追溯的业务目的

每个 AI 场景必须明确业务所有者、输入数据范围、预期输出、可接受风险、人工接管路径和停止条件。平均指标不能取代对高风险样例的人工审阅。

1.2 禁止的自动化决定

招聘、信贷、医疗、法律结论、纪律处分和安全关键控制不得只依赖模型输出。模型只能提供辅助建议，最终决定必须由具备授权的人作出。

2. 知识检索与提示安全

2.1 非受信指令处理

检索内容可能包含要求忽略规则、泄露系统提示或调用外部工具的恶意文本。此类文本仅作为待审查资料，绝不能改变权限、导出数据或绕过审批。

2.2 审查和发布

AI 审查标记敏感信息、注入式提示和质量风险；人工审查确认业务适用性。未审批文档不得参与检索，审查通过也不代表模型对所有问题均正确。

3. 模型与检索变更

3.1 上线前评测

更换模型、修改系统提示、调整检索参数、Chunk 策略或启用 Rerank 前，应运行受控评测。数据集需覆盖正常、歧义、跨文档、过期信息、拒答和攻击样例。

3.2 发布与回滚

对客户可见的重大变更必须保留可回滚版本并观察至少 7 天。若平均 Recall 提升但高风险问答下降，变更不得仅因综合指标上升而发布。

4. 事件、监控与审计

4.1 异常输出

发现虚构、歧视、泄密或越权建议时，应停止自动执行、保存输入输出和请求 ID、确认是否已对外发送并按安全事件流程升级。不得为了清理界面删除证据。

4.2 持续监控

生产至少监控检索命中率、无答案率、引用覆盖率、用户纠正率、拒答率、敏感内容拦截率、模型错误率和人工接管率。每季度更新评测语料和攻击样例。